

INSuRE Fall 2024
Midterm Report - 10/25/2024

Cryptographic Protocol Analysis and Verification

Investigators:

The University of Texas at Dallas Team 1

Nathaniel Simmons - Student Researcher - nis190000@utdallas.edu
Zarish Mehboob - Student Researcher - zxm200007@utdallas.edu
David Leung - Student Researcher - dal190004@utdallas.edu
Arturo Yundt-Pacheco - Student Researcher - aay200001@utdallas.edu
Brian Ricks - Faculty Support - absolutefunk@utdallas.edu

Problem Mentor:

Ed Ziegler - National Security Agency - evziegl@uwe.nsa.gov

Table of Contents

1.0 Project Introduction.....	2
1.1 Top Level Research and Project Description.....	2
1.2 Project Objectives / Goals.....	2
2.0 Research Plan and Progress to Date.....	2
2.1 Research Plan Summary.....	2
2.2 Project Schedule.....	3
2.3 Deliverables.....	4
2.4 Progress to Date.....	4
3.0 Summary of Results.....	7
4.0 Issues and Challenges.....	7
5.0 Bibliography.....	8
5.1 Investigator Biographies.....	8
Appendix A: Acronyms and Terms.....	9
A.1 Acronyms.....	9
A.2 Terms.....	9
Appendix B: CPSA Code.....	10
B.1 Pake0 Implementation.....	10
B.2 Pake1 Implementation.....	11
B.3 SRP3 Implementation.....	12

1.0 Project Introduction

1.1 Top Level Research and Project Description

The goal of the project is to analyze and verify the correctness of a cryptographic protocol in regards to the security properties it intends to provide. We will also potentially propose ways to improve its security and verify the proposed improvements.

1.2 Project Objectives / Goals

The overall goal is to have a report of the results of the verification of a chosen cryptographic protocol and potentially a proposal of improvements to the protocol. Formal verification techniques/tools will be used to perform the work. Each security property that the chosen protocol intends to provide should be verified to be either satisfied or not satisfied. If possible improvements are found, the protocol with the possible improvements can also be verified. Accomplishment of the goal can be measured in terms of how many security properties are successfully verified as either being satisfied or not satisfied. If a security property is unable to be validated, the cause(s) can be further researched to determine if any changes can be made that would allow the property to be validated. If improvements are proposed, then their impact on the protocol's security may also be evaluated. If vulnerabilities are discovered that we cannot immediately suggest a remediation for, then that will be an area of future work.

2.0 Research Plan and Progress to Date

2.1 Research Plan Summary

First, research into our chosen cryptographic protocol of BACnet/SC will be done to ensure understanding of the protocol and its specifications. At the same time, the team will seek education related to the formal verification tools/techniques. Specifically, the team intends to receive training with the Cryptographic Protocol Shapes Analyzer (CPSA) and apply analysis techniques against the protocol. Once the team has sufficient knowledge to begin using the verification tools/techniques, the verification of the protocol will be initiated. The team will utilize CPSA to search for any vulnerabilities in the BACnet/SC protocol. As results are obtained, they will be recorded in the midterm/final reports. If the team comes up with any ideas to potentially improve the protocol, the possible improved protocol can also be verified and those results would be

recorded as well. The project would be considered complete once all security properties of the chosen protocol have been verified as either satisfied or not satisfied.

2.2 Project Schedule

Below is the original project schedule

9/2/24 - 9/8/24	Submit Proposal
9/9/24 - 9/22/24	Start CPSA training and research BACnet/SC protocol
9/23/24 - 10/6/24	Analyze security implementation of protocol
10/7/24 - 10/20/24	Analyze any vulnerabilities discovered
10/21/24 - 10/27/24	Write midterm report and presentation
10/28/24 - 11/10/24	Midterm Presentation & Deliverables (approx.)
11/11/24 - 11/17/24	Generate vulnerability remediations if applicable
11/18/24 - 11/24/24	Verify remediations if applicable
11/25/24 - 12/1/24	Write final report and presentation
12/2/24 - 12/8/24	Final Presentation & Deliverables

Our CPSA training period was extended until 10/17, and implementation of the BACnet protocol in CPSA will take place after the midterm presentations.

Projected schedule

10/28/24 - 11/10/24	Analyze BACnet and implement in CPSA
11/11/24 - 11/17/24	
11/18/24 - 11/24/24	Analyze any vulnerabilities found
11/25/24 - 12/1/24	Recommend mitigations if applicable, time permitting
12/2/24 - 12/8/24	Write final report and present findings

2.3 Deliverables

Completion of CPSA training: 10/17

Our team successfully completed training on the CPSA tool with Enis Golaszewski.

Midterm Report no later than: 10/25

This report provides an update on the team's progress, details the contributions made thus far, and states any issues and challenges found.

Final Report no later than: Dec 6

The final report will provide details regarding the chosen cryptographic protocol, document what was accomplished, and present the finalized findings/results from the analysis and verification of the cryptographic protocol. If there are any suggestions for improvement of the protocol, these will also be documented along with the results (if any) from verifying the protocol with the suggested improvements.

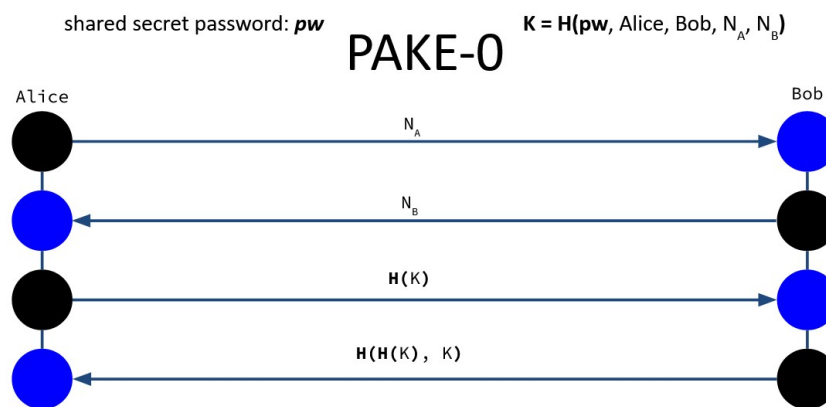
CPSA code no later than: Dec 6

Any and all CPSA code for modeling BACnet/SC should be presentable along with the final presentation and report.

2.4 Progress to Date

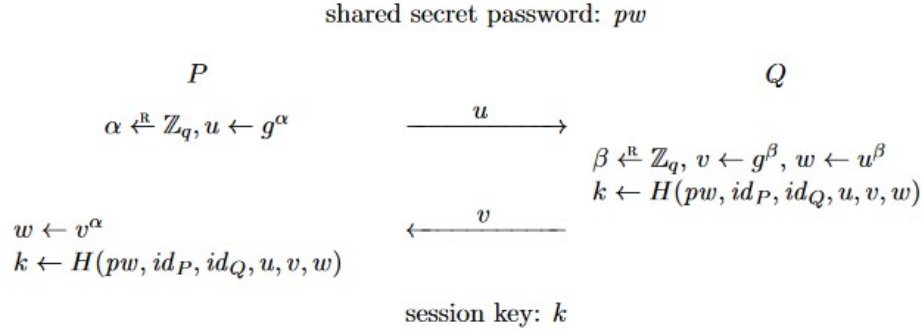
The research team has successfully completed sponsor-mandated training on the CPSA tool.

During this training we first analyzed the Pake0 protocol, which has users share a password, exchange nonces, and agree on a shared key. This is insecure because of the public sharing of the hashed key, and is therefore vulnerable to offline attacks such as dictionary attacks.



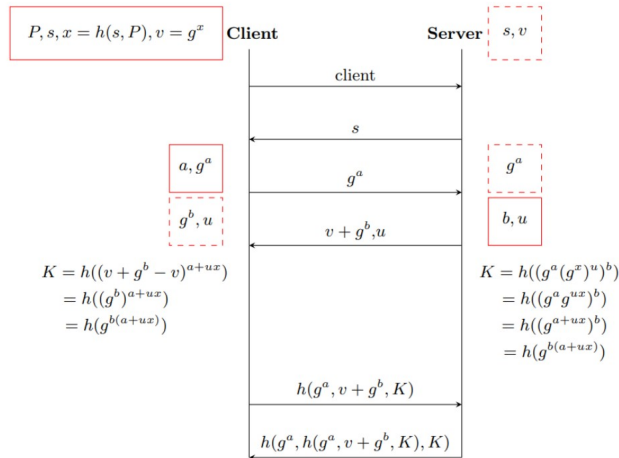
Pake0 protocol overview

The next protocol we modeled was Pake1. Pake1 also has users maintain a shared password, but only nonces are exchanged, not the entire key hash. Therefore attacks such as a dictionary attack are not possible in the same way as Pake0.



Pake1 protocol overview

Lastly, SRP3 is a password authentication protocol that allows remote authentication. It resists dictionary and man-in-the-middle attacks. It also uses asymmetric key cryptography.



SRP3 protocol overview

See appendix B for CPSA code our team created for these protocols.

Additionally, we have acquired the proprietary specification for BACnet Secure Connect and conducted preliminary analyses of the protocol. We have identified key parts of BACnet/SC that will need to be modeled to verify its security.

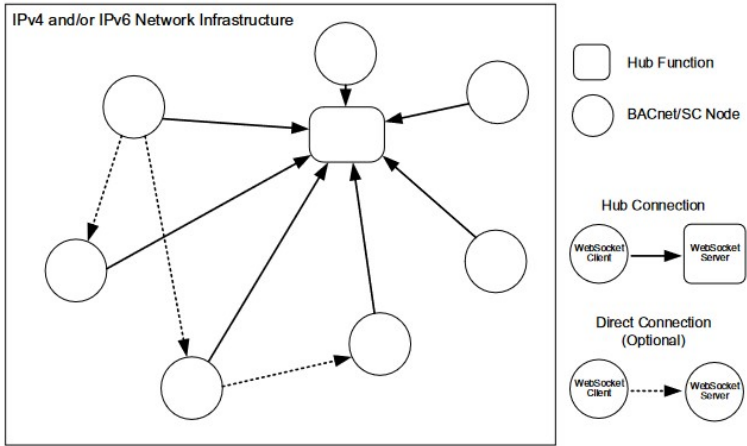


Figure AB-1. BACnet/SC Logical Network Topology

Building Automation and Control Networks, or BACnet, is widely used to manage critical building systems such as HVAC, fire alarms, security, and lighting to name a few. In BACnet, each system is represented by *objects*, which store important properties that describe the system's state or capabilities such as the object type, name, present value, etc. *Services* are used as a method for BACnet devices to communicate with one another. These service requests are sent between devices to perform actions, like adjusting settings or checking system status. This object-service model creates a flexible and efficient way to control and monitor different building systems seamlessly, allowing for integration and automation across various devices.

Object_Name	SPACE TEMP
Object_Type	ANALOG INPUT
Present_Value	72.3
Status_Flags	Normal, InService
High_Limit	78.0
Low_Limit	68.0

The figure above is an example of object properties

An important addendum to the BACnet protocol is BACnet Secure Connect (BACnet/SC) introduces a major enhancement to the BACnet protocol, adding secure, encrypted communication between devices. This update ensures a protected communication channel, preventing unauthorized access and data tampering, which is essential in building automation systems. In BACnet/SC, the security is applied at the transport layer, where Transport Layer Security (TLS) is used to secure WebSocket connections. WebSockets provide an efficient, real-time, full-duplex communication

channel between devices, and when wrapped with TLS this communication is both persistent and secure. TLS adds three key security features: peer authentication, encryption, and message integrity. To ensure peer authentication TLS verifies device identities using digital certificates, ensuring that only trusted devices can communicate. Encryption between devices prevents any unauthorized party from intercepting or reading sensitive information. Lastly, TLS ensures that messages cannot be tampered with during transmission. If altered, the system detects the modification and rejects the data. This combination of WebSockets and TLS guarantees that data remains private, messages are secure from tampering, and only authenticated devices can participate in the BACnet/SC network.

BACnet Layers								Equivalent OSI Layers
BACnet Application Layer								Application
BACnet Network Layer								Network
ISO 8802-2 (IEEE 802.3) Type 1	MS/TP	PTP	LonTalk	BVLL (Annex J)	BVLL (Annex U)	BZLL	Secure Connect BVLL (Annex YY)	Data Link
ISO 8802-3 (IEEE 802.3)	ARCNET	EIA-485		IPv4	IPv6	Zigbee	WebSocket	Physical

3.0 Summary of Results

To enhance our understanding of secure authentication protocols and their potential applications to BACnet, we modeled and verified Pake0, Pake1, and SRP3 in CPSA as part of our training. We have learned the core ideas for modeling in CPSA and understanding its complicated output. With this experience we plan to apply our knowledge and skills towards modeling BACnet/SC.

4.0 Issues and Challenges

- Lack of experience with using formal verification techniques/tools
 - This has been a challenge for the team, but with help from the sponsor and the training, we have been successful in modeling basic protocols
- Protocol Modeling
 - Modeling a protocol can be a challenge depending on how difficult it is to interpret and analyze the protocol specification/documentation. Since BACnet/SC is proprietary we had to request the specification

documentation be purchased by our school, and the documentation is extensively written.

- Additionally, numerous addendums have been made to the protocol. Determining relevance and implementing them may be challenging
- CPSA can't model everything
 - It is possible that some parts of the protocol can't be directly modeled in CPSA. If this is the case, it's possible some workarounds could be devised to model these parts, however the team would be need to provide proof that the model with the workarounds still fundamentally represents the real protocol

5.0 Bibliography

BACnet A Data Communication Protocol for Building Automation and Control Networks. (2020). ASHRAE, 135–2020.
<https://webstore.ansi.org/standards/ashrae/ansiashrae1352020>

5.1 Investigator Biographies

David has a Bachelor's in Computer Science and is working towards a Master's in Computer Science Cybersecurity and has worked in IT Security at Texas Instruments for 2 internships. One of his internship projects dealt with automating password changes, which couldn't have been done securely without cryptography and encryption. He has also taken a cryptography course and has also learned about/applied cryptography concepts as it relates to networks in a network security course.

Zarish recently graduated with a Bachelor's in Computer Science and is currently studying for her Master's in Computer Science with a concentration in cybersecurity. She has had two internships with government organizations. During her most recent internship she analyzed OT protocols and wrote descriptive reports on identified trends. She has a passion for learning about different networking protocols, how they function, and what their vulnerabilities might be. She attended the DOE CIO conference that exposed her to current cybersecurity trends in critical infrastructure that she is determined to incorporate in future projects.

Arturo Yundt-Pacheco is a fourth-year Computer Science undergraduate student completing his final semester for a bachelors at the University of Texas at Dallas, alongside a certificate in Entrepreneurship and Innovation. Throughout this time he has taken classes and worked on projects utilizing several programming languages, both high and low level. He is also currently taking courses to learn about networking

protocols and standards. Outside of classes he has worked to independently increase his cybersecurity knowledge, particularly in topics relevant to incident response such as memory forensics. Outside of the realm of cybersecurity Mr. Yundt-Pacheco has worked on a project with the US Army and an internship with the non-profit NTXIA to develop a keen understanding over operations and organizational strategies.

Nate Simmons recently graduated Cum Laude with his Bachelor's degree in Computer Science, and is continuing to pursue a Master's in Computer Science as a National Science Foundation Scholarship for Service Student. He participates in capture the flag competitions with the computer security group at his university where they are in the top 11% in the US open category. Last summer he completed an internship at Lawrence Livermore National Laboratory. There he focused on finding and demonstrating vulnerabilities in programmable logic controllers. Additionally, he has completed the CompTIA Security+ certification and plans to pursue more professional certifications in the future.

Appendix A: Acronyms and Terms

A.1 Acronyms

ANSI - American National Standards Institute

ASHRAE - The American Society of Heating, Refrigerating and Air-Conditioning Engineers

BACnet - Building Automation and Control Network

BACnet/SC - Building Automation and Control Network Secure Connect

CPSA - Cryptographic Protocol Shapes Analyzer

HVAC&R - Heating, Ventilation, Air Conditioning and Refrigeration

TLS - Transport Layer Security

A.2 Terms

ANSI - A standards institute facilitates the development of consensus standards in the US.

ASHRAE - A professional organization focused on HVAC&R and develop standards related to the field. The paper on BACNET was published in their journal in joint with ANSI.

BACnet - An open, standardized protocol used for communication between building automation and control systems.

BACnet/SC - A security protocol built on top of the BACnet communication protocol.

CPSA - A tool developed by MITRE used to analyze and evaluate the security properties of cryptographic protocols.

HVAC&R - A broad field encompassing the design, installation, operation, and maintenance of systems that control the temperature, humidity, and air quality in buildings.

TLS - A cryptographic protocol that provides security for communication over a computer network.

Appendix B: CPSA Code

B.1 Pake0 Implementation

```
(defprotocol pake0 basic
  (defrole alice
    (vars (a b name) (noncea nonceb data) (pwd skey))
    (trace
      (send noncea)
      (recv nonceb)
      (send (hash pwd noncea nonceb a b))
      (recv (hash (hash pwd noncea nonceb a b) pwd noncea nonceb a b))
    )
  )
  (defrole bob
    (vars (a b name) (noncea nonceb data) (pwd skey))
    (trace
      (recv noncea)
      (send nonceb)
      (recv (hash pwd noncea nonceb a b))
      (send (hash (hash pwd noncea nonceb a b) pwd noncea nonceb a b))
    )
  )
)

(defskeleton pake0
  (vars (a b name) (noncea nonceb data) (pwd skey))
  (defstrandmax alice (a a) (b b) (noncea noncea) (nonceb nonceb) (pwd pwd))
  (uniq-orig noncea nonceb)
  (pen-non-orig pwd)
)

(defskeleton pake0
  (vars (a b name) (noncea nonceb data) (pwd skey))
```

```

      (defstrandmax bob (a a) (b b) (noncea noncea) (nonceb nonceb) (pwd pwd))
      (uniq-orig noncea nonceb)
      (pen-non-orig pwd)
    )
  (defskelton pake0
    (vars (a b name) (noncea nonceb data) (pwd skey))
    (defstrandmax alice (a a) (b b) (noncea noncea) (nonceb nonceb) (pwd pwd))
    (deflistener pwd)
    (uniq-orig noncea nonceb)
    (pen-non-orig pwd)
  )
  (defskelton pake0
    (vars (a b name) (noncea nonceb data) (pwd skey))
    (defstrandmax bob (a a) (b b) (noncea noncea) (nonceb nonceb) (pwd pwd))
    (deflistener pwd)
    (uniq-orig noncea nonceb)
    (pen-non-orig pwd)
  )
)

```

B.2 Pake1 Implementation

```

(defprotocol pake1 basic
  (defrole alice
    (vars (a b name) (na nb rndx) (pwd skey))
    (trace
      (send (exp (gen) na));; u
      (recv (exp (gen) nb));; v
      ;; send H(k)
      (send (hash (hash pwd a b (exp (gen) na) (exp (gen) nb) (exp (exp (gen) na)
nb)))) ;; h(pwd a b u v w) = k
      ;; send H(H(k) k)
      (recv (hash (hash (hash pwd a b (exp (gen) na) (exp (gen) nb) (exp (exp (gen)
na)nb)))) (hash pwd a b (exp (gen) na) (exp (gen) nb) (exp (exp (gen) na) nb))))
    )
    (uniq-gen na)
  )
  (defrole bob
    (vars (a b name) (na nb rndx) (pwd skey))
    (trace
      (recv (exp (gen) na));; u
      (send (exp (gen) nb));; v

```

```

;; send H(k)
(recv (hash (hash pwd a b (exp (gen) na) (exp (gen) nb) (exp (exp (gen) na)
nb)))) ;; h(pwd a b u v w) = k
;; send H(H(k) k)
(send (hash (hash (hash pwd a b (exp (gen) na) (exp (gen) nb) (exp (exp (gen)
na)nb)))) (hash pwd a b (exp (gen) na) (exp (gen) nb) (exp (exp (gen) na) nb))))
)
(uniq-gen nb)
)
)
(defskeleton pake1
  (vars (a b name) (na nb rndx) (pwd skey))
  (defstrandmax alice (a a) (b b) (na na) (pwd pwd))
  (pen-non-orig pwd)
)
(defskeleton pake1
  (vars (a b name) (na nb rndx) (pwd skey))
  (defstrandmax bob (a a) (b b) (nb nb) (pwd pwd))
  (pen-non-orig pwd)
)

```

B.3 SRP3 Implementation

```

(defprotocol srp basic
  (defrole client
    ;; pwd salt x(hash) na nb
    (vars (c name) (a b u x rndx) (salt data) (gx locn))
    (trace
      (load gx "init")
      (stor gx (exp (gen) x))
      (send c)
      (recv salt)
      (send (exp (gen) a))
      (recv (cat (enc (exp (gen) b) (exp (gen) x)) u))
      ;;  $K = (\text{hash}(\text{hash}(\text{exp}(\text{gen}) (\text{mul } a \ b)) (\text{exp}(\text{gen}) (\text{mul } b \ u \ x))))$ 
      ;;  $h(g^a(ab) + g^a(bux)) = h(g^a(ab + bux))$ 
      (send (hash (exp (gen) a) (enc (exp (gen) b) (exp (gen) x)) (hash (hash (exp
(gen) (mul a b)) (exp (gen) (mul b u x))))))
      ;; h( $g^a$  above K)
      (recv (cat (hash (exp (gen) a) ;;  $g^a$ 

```

```

    (hash (exp (gen) a) (enc (exp (gen) b) (exp (gen) x)) (hash (hash (exp (gen) (mul
a b)) (exp (gen) (mul b u x)))))) ;; h( g^(ab) + g^(bux)) = h( g^(ab + bux))
    (hash (hash (exp (gen) (mul a b)) (exp (gen) (mul b u x)))))) ;; K
  )
  (uniq-gen a x)
)
(defrole server
  (vars (c name) (a b u x rndx) (salt data) (gx locn))
  (trace
    (load gx (exp (gen) x))
    (recv c)
    (send salt)
    (recv (exp (gen) a))
    (send (cat (enc (exp (gen) b) (exp (gen) x)) u))
    ;; K = (hash (hash (exp (gen) (mul a b)) (exp (gen) (mul b u x))))
    ;; h( g^(ab) + g^(bux)) = h( g^(ab + bux))
    (recv (hash (exp (gen) a) (enc (exp (gen) b) (exp (gen) x)) (hash (hash (exp (gen)
(mul a b)) (exp (gen) (mul b u x))))))
    ;; h( g^a above K)
    (send (cat (hash (exp (gen) a) ;; g^a
    (hash (exp (gen) a) (enc (exp (gen) b) (exp (gen) x)) (hash (hash (exp (gen) (mul
a b)) (exp (gen) (mul b u x)))))) ;; h( g^(ab) + g^(bux)) = h( g^(ab + bux))
    (hash (hash (exp (gen) (mul a b)) (exp (gen) (mul b u x)))))) ;; K
  )
  (uniq-gen b u)
)
)
(defskeleton srp
  (vars (c name) (a b u x rndx) (salt data))
  (defstrandmax client (c c) (a a) (b b) (u u) (x x) (salt salt))
)
(defskeleton srp
  (vars (c name) (a b u x rndx) (salt data))
  (defstrandmax server (c c) (a a) (b b) (u u) (x x) (salt salt))
  (deflistener x)
  (uniq-gen x)
)
)

```